
**Tecnologias da informação — Governança
de TI — Avaliação da governança de tecnologia
da informação**

*Information technology — Governance of IT — Assessment of the
governance of IT*

ICS 35.020



ASSOCIAÇÃO
BRASILEIRA
DE NORMAS
TÉCNICAS

Número de referência
ABNT NBR IEC 38503:2025
34 páginas

© IEC 2022 - © ABNT 2025



© IEC 2022

Todos os direitos reservados. A menos que especificado de outro modo, nenhuma parte desta publicação pode ser reproduzida ou utilizada por qualquer meio, eletrônico ou mecânico, incluindo fotocópia e microfilme, sem permissão por escrito da ABNT, único representante da ISO no território brasileiro.

© ABNT 2025

Todos os direitos reservados. A menos que especificado de outro modo, nenhuma parte desta publicação pode ser reproduzida ou utilizada por qualquer meio, eletrônico ou mecânico, incluindo fotocópia e microfilme, sem permissão por escrito da ABNT.

ABNT

Rua Conselheiro Nebias, 1.131

01203-002 - São Paulo - SP

Tel.: + 55 11 3017-3600

abnt@abnt.org.br

www.abnt.org.br

Sumário

Página

Prefácio Nacional	v
Introdução	vi
1 Escopo	1
2 Referências normativas	1
3 Termos e definições	1
4 Benefícios da avaliação da governança de TI	2
4.1 Contexto	2
4.2 Benefícios ao avaliar a governança de TI	3
5 Escopo e método de avaliação	3
5.1 Estabelecer escopo	3
5.2 Abordagem de avaliação e partes envolvidas	5
5.3 Papéis, responsabilidades e competências	6
5.3.1 Papéis associados à avaliação da governança de TI	6
5.3.2 Órgão de governança	6
5.3.3 Patrocinador	7
5.3.4 Diretoria executiva	8
5.3.5 Especialista em avaliação (avaliador)	8
5.3.6 Especialista em negócios	9
5.3.7 Especialista técnico	9
6 Avaliação da governança de TI	10
6.1 Visão geral da avaliação	10
6.2 Modelo de referência para a governança de TI	11
6.2.1 Áreas de prática para a governança de TI	11
6.2.2 Características para a governança de TI	12
6.2.3 Modelo de medição para a governança de TI	12
6.2.4 Estrutura de avaliação para a governança de TI	13
6.3 Avaliação da governança de TI	15
6.4 Modelo de maturidade para governança de TI	15
7 Atividades de avaliação	19
7.1 Planejamento da avaliação	19
7.2 Realização da avaliação	20
7.2.1 Coleta dos dados	20
7.2.2 Condução da avaliação	20
7.3 Notificar a avaliação	21
Anexo A (informativo) Estrutura de avaliação – Áreas de prática para a governança de TI	22
Figuras	
Figura 1 – Domínios a serem considerados na avaliação da governança de TI	4
Figura 2 – Visão geral da avaliação da governança de TI	11
Figura 3 – Áreas de prática, suas três categorias e características distintas para governança de TI	12

Figura 4 – Estrutura de avaliação para a governança de TI.....14

Figura 5 – Exemplo de representação gráfica para uma avaliação da governança de TI.....15

Tabelas

Tabela 1 – Principais aspectos a serem considerados na avaliação da governança de TI.....4

Tabela 2 – Abordagem de avaliação e principais considerações.....5

Tabela 3 – Responsabilidades e habilidades/conhecimentos do órgão de governança.....7

Tabela 4 – Responsabilidades e habilidades/conhecimentos do patrocinador.....8

Tabela 5 – Responsabilidades e habilidades/conhecimentos da diretoria executiva.....8

Tabela 6 – Responsabilidades e habilidades/conhecimentos do especialista
em avaliação (avaliador).....9

Tabela 7 – Responsabilidades e habilidades/conhecimentos do especialista em negócios.....9

Tabela 8 – Responsabilidades e habilidades/conhecimentos do especialista técnico.....10

Tabela 9 – Escala de avaliação de medição.....13

Tabela 10 – Modelo de maturidade para a governança de TI.....16

Tabela A.1 – Mecanismos de habilitação.....23

Tabela A.2 – Responsabilidade.....25

Tabela A.3 – Estratégia.....26

Tabela A.4 – Aquisição.....28

Tabela A.5 – Desempenho.....30

Tabela A.6 – Conformidade.....31

Tabela A.7 – Comportamento humano.....33

Prefácio Nacional

A Associação Brasileira de Normas Técnicas (ABNT) é o Foro Nacional de Normalização. As Normas Brasileiras, cujo conteúdo é de responsabilidade dos Comitês Brasileiros (ABNT/CB), dos Organismos de Normalização Setorial (ABNT/ONS) e das Comissões de Estudo Especiais (ABNT/CEE), são elaboradas por Comissões de Estudo (CE), formadas pelas partes interessadas no tema objeto da normalização.

Os Documentos Técnicos internacionais adotados são elaborados conforme as regras da ABNT Diretiva 3.

AABNT chama a atenção para que, apesar de ter sido solicitada manifestação sobre eventuais direitos de patentes durante a Consulta Nacional, estes podem ocorrer e devem ser comunicados à ABNT a qualquer momento (Lei nº 9.279, de 14 de maio de 1996).

Os Documentos Técnicos ABNT, assim como as Normas Internacionais (ISO e IEC), são voluntários e não incluem requisitos contratuais, legais ou estatutários. Os Documentos Técnicos ABNT não substituem Leis, Decretos ou Regulamentos, aos quais os usuários devem atender, tendo precedência sobre qualquer Documento Técnico ABNT.

Ressalta-se que os Documentos Técnicos ABNT podem ser objeto de citação em Regulamentos Técnicos. Nestes casos, os órgãos responsáveis pelos Regulamentos Técnicos podem determinar as datas para exigência dos requisitos de quaisquer Documentos Técnicos ABNT.

AABNT NBR IEC 38503 foi elaborada no Comitê Brasileiro de Tecnologias da Informação e Transformação Digital (ABNT/CB-021), pela Comissão de Estudo de Gestão e Governança de TI (CE-021:004.040). O Projeto foi submetido à Consulta Nacional no período de 04.11.2025 a 03.12.2025.

A ABNT NBR IEC 38503 é uma adoção idêntica, em conteúdo técnico, estrutura e redação, à IEC 38503:2022, que foi elaborada pelo *Joint Technical Committee Information Technology* (ISO/IEC JTC 1), *Subcommittee IT service management and IT governance* (SC 40).

O Escopo em inglês da ABNT NBR IEC 38503 é o seguinte:

Scope

This document provides guidance on the assessment of governance of information technology (IT) based on the principles, definitions and model for the governance of IT outlined in ABNT NBR ISO/IEC 38500 and ISO/IEC TR 38502 and the implementation considerations outlined in ISO/IEC TS 38501.

This document includes approaches for conducting the assessment, the criteria against which the assessment can be made, guidance on the evidence that can be used for the assessment, as well as a method for determining the maturity of the organization's governance of IT.

This document is applicable to organizations of all sizes, regardless of the extent of their use of IT.

Introdução

Como parte de sua responsabilização por uma organização, os órgãos de governança são responsáveis pelo uso atual e futuro de TI (tecnologia da informação) dentro de uma organização. Para cumprir essa obrigação, recomenda-se que os membros do órgão de governança assegurem que haja uma governança efetiva de TI dentro da organização, envolvendo tanto suas próprias atividades na definição da direção para o uso organizacional de TI, quanto sua supervisão e avaliação da gestão de TI dentro da organização.

AABNT NBR ISO/IEC 38500 fornece princípios, definições e um modelo para os órgãos de governança usarem ao avaliar, direcionar e monitorar o uso de TI em suas organizações. Este documento fornece orientações sobre como avaliar a governança de uma organização de arranjos de TI com base nas ABNT NBR ISO/IEC 38500, ISO/IEC TS 38501 e ISO/IEC TR 38502.

Os arranjos específicos para a governança de TI variam de organização para organização. A variação depende de vários fatores, incluindo o nível de dependência da organização da TI, tanto estratégica quanto operacionalmente, bem como o tamanho e a natureza da organização.

Convém que os órgãos de governança busquem a melhoria contínua da governança de TI como parte de sua responsabilização geral pela governança da organização e convém que avaliem se os acordos atuais atendem às necessidades da organização. Convém que esses acordos usem essa avaliação para melhorar a eficácia da governança de TI de forma estruturada, com uma abordagem planejada. Convém que a avaliação trate não apenas da abordagem da direção para apoiar a governança de TI, mas também da eficácia de sua própria abordagem para avaliar, dirigir e monitorar as atividades de gestão.

O objetivo deste documento é auxiliar os órgãos de governança, subcomitês autorizados e outras partes interessadas importantes na avaliação da capacidade e maturidade dos arranjos para a governança de TI na organização.

Este documento fornece uma abordagem objetiva para determinar se o órgão de governança governa adequadamente a TI, bem como exemplos das práticas e resultados (referidos como “características” neste documento) da boa governança de TI (ver Tabelas A.1 a A.7 do Anexo A). Os resultados da avaliação podem ser usados para ajudar o órgão de governança a determinar onde e como governança de TI pode ser melhorada na organização.

Os principais públicos deste documento são o órgão de governança e seus subcomitês, diretoria executiva e avaliadores, que também se beneficiam deste documento ao planejar e conduzir uma avaliação da governança de TI da organização.

Tecnologias da informação — Governança de TI — Avaliação da governança de tecnologia da informação

1 Escopo

Este documento fornece orientações sobre a avaliação da governança de tecnologia de informação (TI) com base nos princípios, definições e modelo para a governança de TI descritos na ABNT NBR ISO/IEC 38500 e no ISO/IEC TR 38502, bem como nas considerações de implementação descritas na ISO/IEC TS 38501.

Este documento inclui abordagens para conduzir a avaliação, os critérios contra os quais a avaliação pode ser feita, orientações sobre as evidências que podem ser usadas para a avaliação, bem como um método para determinar a maturidade da governança de TI da organização.

Este documento é aplicável a organizações de todos os tamanhos, independentemente da extensão do uso de TI.

2 Referências normativas

Os documentos a seguir são citados no texto de tal forma que seus conteúdos, totais ou parciais, constituem requisitos para este Documento. Para referências datadas, aplicam-se somente as edições citadas. Para referências não datadas, aplicam-se as edições mais recentes do referido documento (incluindo emendas).

ABNT NBR ISO/IEC 38500, *Tecnologia da informação – Governança de TI para a organização*

ISO/IEC TS 38501, *Information technology – Governance of IT – Implementation guide*

ISO/IEC TR 38502, *Information technology – Governance of IT – Framework and model*

3 Termos e definições

Para os efeitos deste documento, aplicam-se os seguintes termos e definições.

A ISO e a IEC mantêm bases de dados terminológicos para uso na normalização nos seguintes endereços:

— ISO *Online browsing platform*: disponível em <https://www.iso.org/obp>

— IEC *Electropedia*: disponível em <https://www.electropedia.org>

3.1

resultado benéfico

realização de um objetivo de alto nível da organização, relacionado à implantação e uso bem-sucedidos da tecnologia da informação

3.2

evidência de sucesso

resultados observáveis e mensuráveis de funções/processos de tecnologia da informação que suportam e habilitam a obtenção de resultados benéficos

4 Benefícios da avaliação da governança de TI

4.1 Contexto

A governança de TI envolve comportamentos apropriados de órgãos de governança e de gestão para criar e manter uma estrutura para o uso de TI, que ofereça valor de longo prazo consistente com as expectativas de suas partes interessadas, incluindo:

- inovação contínua em serviços, mercados e negócios;
- clareza de responsabilidade e responsabilização tanto pela oferta quanto pela demanda de TI para atingir os objetivos estratégicos da organização;
- garantia de continuidade e sustentabilidade do negócio por meio de TI;
- realização dos benefícios esperados de cada investimento em TI;
- conformidade com as obrigações pertinentes (regulatórias, legislativas, de direito comum, contratuais);
- supervisão eficaz da gestão de riscos de TI;
- relacionamentos construtivos e comunicações eficazes entre o negócio e a gestão de TI, e com parceiros externos.

No entanto, as organizações podem enfrentar uma ampla variedade de desafios, o que pode impedi-las de alcançar os resultados desejados de seus esforços para governar a TI, incluindo:

- o órgão de governança e os diretores executivos delegando a responsabilidade pela governança de TI aos responsáveis pela implementação da tecnologia;
- a falta de políticas e estruturas que esclareçam a relação entre governança de TI e gerenciamento de TI;
- dependência de processos organizacionais, em vez de tomada de decisão eficaz, comportamentos apropriados, comunicação adequada e interações humanas adequadas;
- dificuldade de monitorar e medir comportamentos e resultados esperados, incluindo:
 - garantia de que os objetivos de TI estejam alinhados ao propósito e aos objetivos da organização;
 - garantia de que os riscos de TI sejam conhecidos e mitigados;
 - administração de ativos corporativos, recursos e planejamento de continuidade;
 - conformidade da organização com as normas de comportamento estabelecidas e esperadas;
 - responsabilização da TI pela entrega de serviços e soluções;
 - evolução dos modelos de negócio por meio do uso de informações e da adoção de novas tecnologias.

4.2 Benefícios ao avaliar a governança de TI

É importante, portanto, que as organizações adotem um método estruturado para avaliar se sua governança de TI está alcançando os resultados desejados e os principais benefícios, incluindo:

- auxiliar no desenvolvimento da estrutura para a governança de TI;
- determinar os pontos fortes e fracos da atual governança da capacidade de TI;
- ajudar a determinar ações de melhoria que precisam ser tomadas;
- melhorar os níveis de envolvimento entre os diretores executivos e o órgão de governança no que diz respeito às expectativas e aos resultados relacionados com a governança de TI;
- criar uma consciência no órgão de governança de seus papéis e responsabilidades em relação à governança de TI;
- auxiliar as organizações mantendo a conformidade de TI;
- fornecer *feedback* às partes interessadas de governança e à equipe de suporte.

5 Escopo e método de avaliação

5.1 Estabelecer escopo

O órgão de governança deve definir o escopo e os requisitos e objetivos da avaliação. O órgão de governança deve identificar as partes interessadas que exigem ou podem se beneficiar dos resultados de uma avaliação da governança de TI. Para estas partes interessadas, as necessidades e expectativas devem ser consideradas na preparação da avaliação.

Ao estabelecer o escopo, o foco e a prioridade da avaliação, deve-se considerar a avaliação de questões da mais alta importância para a organização, a fim de obter os maiores benefícios e não desperdiçar recursos. Isso pode levar em conta o nível de dependência operacional da TI, a existência de insumos de garantia, bem como quaisquer iniciativas estratégicas específicas de importância e prioridade para a organização.

A Figura 1 mostra as áreas relacionadas à implementação da governança de TI, conforme descrito na ISO/IEC TS 38501, que devem ser consideradas na definição do escopo da avaliação.

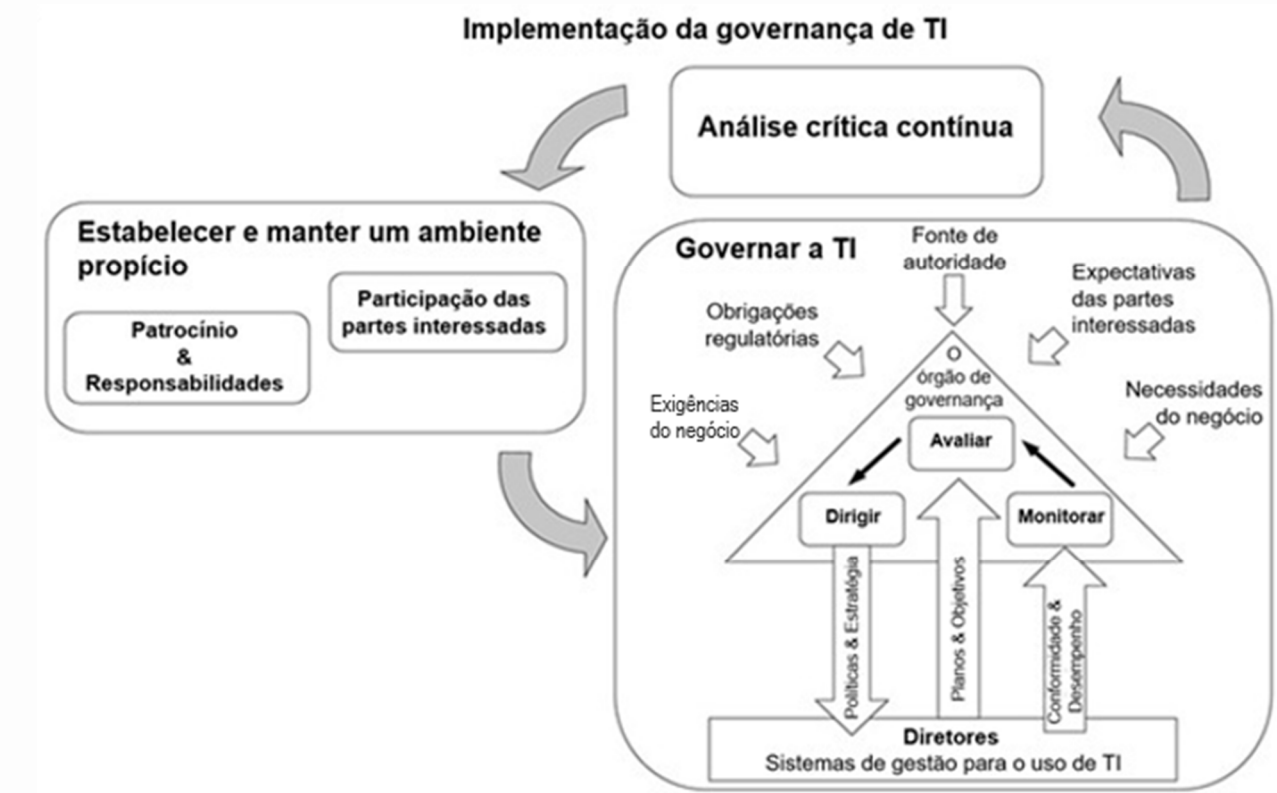


Figura 1 – Domínios a serem considerados na avaliação da governança de TI
[FONTE: ISO/IEC TS 38501:2015, Figura 1]

A Tabela 1 identifica os principais aspectos relacionados à implementação da governança de TI, conforme descrito na ISO/IEC TS 38501, que devem ser considerados ao definir o escopo da avaliação.

Tabela 1 – Principais aspetos a serem considerados na avaliação da governança de TI

Estabelecer e manter um ambiente propício
— metas e objetivos de governança de TI — compreensão das partes interessadas, papéis e responsabilidades — participação das partes interessadas — delegação de poderes
Governar a TI
— aplicação dos seis princípios e do modelo EDM — grupo diretor de governança — ambientes interno e externo — articulação dos estados atuais e desejados e resultados benéficos — capacidade de monitorização e identificação de evidências de sucesso — programa de mudança
Análise crítica contínua
— melhoria do valor derivado da TI — gestão de riscos associados às TI — ações adicionais de governança necessárias

5.2 Abordagem de avaliação e partes envolvidas

Ao estabelecer uma abordagem de avaliação, deve-se levar em consideração os objetivos/finalidade da avaliação, o grau de independência exigido para a avaliação, as habilidades/conhecimentos dos avaliadores e participantes e outras considerações relevantes dependentes dos arranjos específicos para a governança de TI dentro da organização.

A abordagem de avaliação deve ser aprovada pelo órgão de governança. Deve ser apoiada com os detalhes da estrutura de avaliação, um plano de avaliação, papéis e responsabilidades dos avaliadores, cronograma da avaliação, recursos necessários para a avaliação e uma compreensão das habilidades e conhecimentos dos avaliadores.

Existem diferentes abordagens para a avaliação da governança de TI. As abordagens de avaliação e as principais considerações estão resumidas na Tabela 2.

Tabela 2 – Abordagem de avaliação e principais considerações (continua)

	Avaliação do órgão de governança	Avaliação facilitada internamente	Avaliação facilitada externamente
Descrição	Avaliação da governança de TI realizada pelo órgão de governança; isso pode ser considerado semelhante a uma autoavaliação.	Avaliação da governança de TI realizada por recursos internos aprovados, qualificados e conhecedores ou avaliadores para apoiar a avaliação.	Avaliação da governança de TI realizada por recursos externos ou avaliadores aprovados qualificados e conhecedores para apoiar a avaliação.
Objetivo/ Finalidade	— autoavaliação de alto nível — permite que o órgão regulador monitore seu próprio desempenho em relação à governança de TI	— avaliação interna detalhada — fornece ao órgão de governança uma perspectiva interna sobre até que ponto ele está cumprindo suas responsabilidades em relação à governança de TI	— avaliação externa independente detalhada — fornece ao órgão de governança uma perspectiva externa sobre até que ponto ele está cumprindo suas responsabilidades em relação à governança de TI
Benefícios	— velocidade/ facilidade — sem dependência de avaliadores (internos ou externos)	— envolvimento mais amplo (diretoria executiva) — maior nível de informação considerado	— maior objetividade — capacidade de suportar requisitos de relatórios externos

Tabela 2 (conclusão)

	Avaliação do órgão de governança	Avaliação facilitada internamente	Avaliação facilitada externamente
Participantes	— órgão de governança	— órgão de governança — diretoria executiva — especialistas técnicos e de negócio	— órgão de governança — diretoria executiva — especialistas técnicos e de negócio
Assessor	— membro do órgão de governança	— avaliador(es) interno(s)	— avaliador(es) independente(s) externo(s)
Fatores de sucesso	— o órgão de governança deve se comprometer a realizar a autoavaliação e agir de acordo com suas conclusões	— o órgão de governança deve se comprometer a apoiar a avaliação interna e a agir de acordo com as suas conclusões — o recurso interno tem a autoridade necessária para avaliar o órgão de governança	— o órgão de governança deve se comprometer a apoiar a avaliação externa e a agir de acordo com as suas conclusões

5.3 Papéis, responsabilidades e competências

5.3.1 Papéis associados à avaliação da governança de TI

A seguir estão os papéis importantes no contexto da avaliação da governança de TI. Uma descrição completa é fornecida para cada função nas seguintes subseções:

- órgão de governança (ver 5.3.2);
- patrocinador (ver 5.3.3);
- diretoria executiva (ver 5.3.4);
- especialista em avaliação (avaliador) (ver 5.3.5);
- especialista em negócios (ver 5.3.6);
- especialista técnico (ver 5.3.7).

5.3.2 Órgão de governança

O órgão de governança é um papel fundamental na avaliação. Ele fornece a direção geral para a avaliação e assegura que a avaliação agregue valor ao objetivo geral de governança. No caso de o órgão de governança realizar a avaliação por conta própria, existem responsabilidades adicionais e requisitos de habilidades/conhecimentos. Estes são mostrados na Tabela 3.

Tabela 3 – Responsabilidades e habilidades/conhecimentos do órgão de governança

Responsabilidades	Habilidades/conhecimentos
— Geral: — estabelecer os principais objetivos da avaliação; — aprovar o escopo e a abordagem da avaliação; — permitir que a gerência diretoria atinja os principais objetivos da avaliação; — avaliar se a avaliação fornece os resultados desejados de acordo com os principais objetivos; — assegurar que a avaliação acrescente valor aos objetivos globais de governança; aprovar/rejeitar o relatório de avaliação formal apresentado pelo patrocinador. — Avaliação do órgão de governança: — as responsabilidades gerais descritas acima continuam a ser aplicáveis; — se houver uma lacuna nas competências para realizar a avaliação, nomear os membros relevantes para adquirir as competências para realizar a avaliação; — gerenciar os aspectos operacionais da avaliação e a produção do relatório.	— Geral: — convém que tenha um conhecimento básico das ABNT NBR ISO/IEC 38500, ISO/IEC TS 38501 e ISO/IEC TR 38502; — deve compreender o contexto interno e externo dentro do qual a organização opera. — Avaliação do órgão de governança: — os membros do órgão de governança que participam como avaliadores devem ter as habilidades e conhecimentos necessários para conduzir a avaliação do órgão de governança, quando necessário.

5.3.3 Patrocinador

O patrocinador é um membro do órgão de governança. O patrocinador garante que o escopo da avaliação seja finalizado e que os recursos necessários para a realização da avaliação estejam disponíveis. As responsabilidades do patrocinador e os requisitos de habilidades/conhecimentos são mostrados na Tabela 4.

Tabela 4 – Responsabilidades e habilidades/conhecimentos do patrocinador

Responsabilidades	Habilidades/conhecimentos
— finalizar e aprovar o plano para a avaliação; — assegurar a disponibilidade dos recursos necessários para a realização da avaliação; — assegurar que o avaliador tenha acesso aos especialistas de negócios e técnicos necessários durante a avaliação; — analisar criticamente o relatório final e a submissão ao órgão de governança.	— convém que tenha um conhecimento básico das ABNT NBR ISO/IEC 38500, ISO/IEC TS 38501 e ISO/IEC TR 38502; — deve compreender o contexto interno e externo dentro do qual a organização opera.

5.3.4 Diretoria executiva

A diretoria executiva segue as diretrizes do órgão de governança em relação à avaliação e fornece ao avaliador os dados e o suporte necessários. As responsabilidades da diretoria executiva e os requisitos de habilidades/conhecimentos são mostrados na Tabela 5.

Tabela 5 – Responsabilidades e habilidades/conhecimentos da diretoria executiva

Responsabilidades	Habilidades/conhecimentos
— trabalhar para alcançar os principais objetivos da avaliação; — analisar criticamente o plano de avaliação conforme preparado pelo avaliador, quando necessário; — fornecer ao avaliador os dados de avaliação necessários e acesso a especialistas técnicos e de negócios; — analisar criticamente a exatidão e a integridade do relatório de avaliação; — gerenciar a comunicação entre o órgão de governança e o cliente e consumidor final.	— convém que tenha um conhecimento básico das ABNT NBR ISO/IEC 38500, ISO/IEC TS 38501 e ISO/IEC TR 38502; — deve compreender o contexto interno e externo em que a organização opera; — convém que construa confiança e responsabilização pessoal entre todos os papéis participantes.

5.3.5 Especialista em avaliação (avaliador)

O especialista em avaliação (avaliador) é o indivíduo ou grupo de indivíduos que realiza a avaliação real. As responsabilidades do avaliador e os requisitos de habilidades/conhecimentos são mostrados na Tabela 6.

Tabela 6 – Responsabilidades e habilidades/conhecimentos do especialista em avaliação (avaliador)

Responsabilidades	Habilidades/conhecimentos
— compreender e documentar os objetivos da avaliação; — verificar se a abordagem de avaliação foi aprovada; — verificar se o escopo da avaliação está adequadamente estabelecido antes do início da avaliação; — preparar o plano de avaliação e conduzir as atividades de acordo com o plano de avaliação; — elaborar e apresentar o relatório de avaliação.	— deve ter um bom conhecimento das ABNT NBR ISO/IEC 38500, ISO/IEC TS 38501 e ISO/IEC TR 38502 e da estrutura de avaliação; — deve compreender a governança dos arranjos de TI dentro da organização e os vários papéis e suas contribuições; — deve ter um bom conhecimento das normas e das melhores práticas de avaliação, e deve ter experiência que lhe permita aplicá-las na avaliação.

5.3.6 Especialista em negócios

O especialista em negócios é o indivíduo ou grupo de indivíduos que constitui o recurso interno que fornece os dados de negócios necessários para realizar a avaliação real. As responsabilidades do especialista em negócios e os requisitos de habilidades/conhecimentos são mostrados na Tabela 7.

Tabela 7 – Responsabilidades e habilidades/conhecimentos do especialista em negócios

Responsabilidades	Habilidades/conhecimentos
— compreender o escopo e o objetivo da avaliação; — fornecer conhecimento de domínio de negócios necessário durante a avaliação.	— convém que tenha conhecimento básico dos benefícios comerciais das ABNT NBR ISO/IEC 38500, ISO/IEC TS 38501 e ISO/IEC TR 38502; — deve ter bom conhecimento e compreensão dos processos e procedimentos de negócios da organização; — convém que entenda como a TI pode permitir a inovação e transformação dos negócios e a geração de valor.

5.3.7 Especialista técnico

O especialista técnico é o indivíduo ou grupo de indivíduos que constitui os recursos internos que fornecem o conhecimento técnico necessário e o suporte necessário para realizar a avaliação real. As responsabilidades do especialista técnico e os requisitos de habilidades/conhecimentos são mostrados na Tabela 8.

Tabela 8 – Responsabilidades e habilidades/conhecimentos do especialista técnico

Responsabilidades	Habilidades/conhecimentos
— compreender o escopo e o objetivo da avaliação; — fornecer os conhecimentos técnicos necessários durante a avaliação.	— convém que tenha um bom conhecimento das ABNT NBR ISO/IEC 38500, ISO/IEC TS 38501 e ISO/IEC TR 38502; — deve compreender os riscos técnicos e as mitigações; — convém que entenda como a TI pode permitir a inovação e transformação dos negócios e a geração de valor; — convém que compreenda os aspectos regulatórios das novas tecnologias.

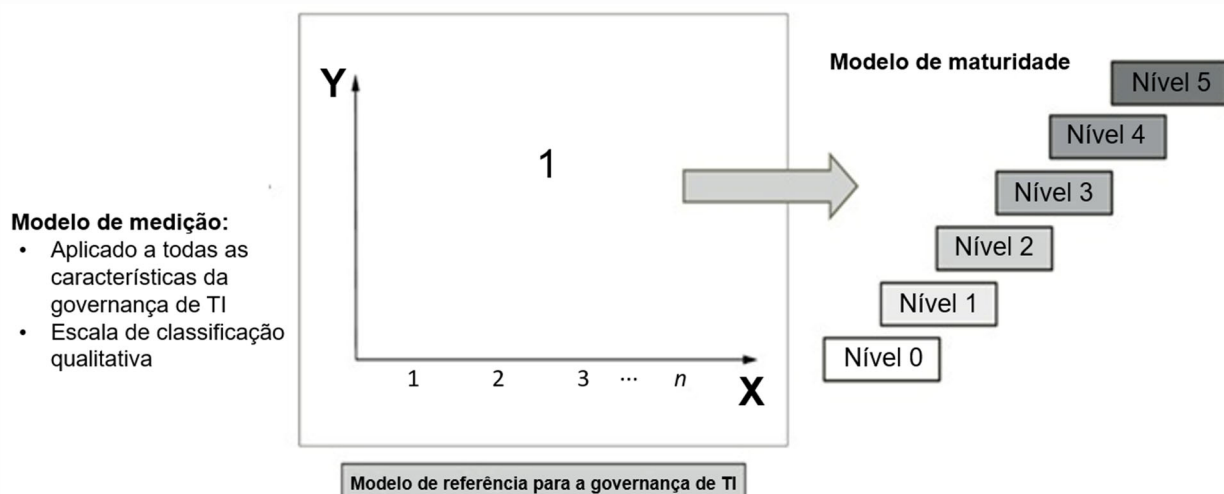
6 Avaliação da governança de TI

6.1 Visão geral da avaliação

A avaliação da governança de TI deve ser realizada utilizando o modelo de referência para a governança de TI, que deriva das normas fundamentais, nomeadamente as ABNT NBR ISO/IEC 38500, ISO/IEC TS 38501 e ISO/IEC TR 38502. O modelo de referência compreende quatro componentes:

- áreas de prática para a governança de TI (ver 6.2.1);
- características para a governança de TI (ver 6.2.2);
- modelo de medição para a governança de TI (ver 6.2.3);
- estrutura de avaliação para a governança de TI (ver 6.2.4).

A Figura 2 mostra a inter-relação desses conceitos.



Legenda

- 1 avaliação da governança de TI
- X governança das áreas de prática de TI
- Y classificação

Figura 2 – Visão geral da avaliação da governança de TI

6.2 Modelo de referência para a governança de TI

6.2.1 Áreas de prática para a governança de TI

As áreas de prática para a governança de TI representam as principais áreas de foco para a organização ao governar efetivamente a TI. Sete áreas de atuação foram identificadas, sendo a primeira derivada das ISO/IEC TS 38501 e ISO/IEC TR 38502. As outras seis áreas de atuação são derivadas dos princípios da ABNT NBR ISO/IEC 38500:

- Mecanismos facilitadores;
- Responsabilização;
- Estratégia;
- Aquisição;
- Desempenho;
- Conformidade;
- Comportamento humano.

NOTA BRASILEIRA O primeiro parágrafo cita seis princípios da ABNT NBR ISO/IEC 38500, mas lista sete. O erro foi mantido para seguir o vice-versa.

Em 6.2.2 e no Anexo A são fornecidas mais informações sobre o conteúdo abordado em cada área de atuação.

6.2.2 Características para a governança de TI

Cada área de prática contém três categorias com características distintas, conforme definido nas normas básicas:

- tarefas e práticas de governança (avaliar, dirigir e monitorar);
- evidência de sucesso (resultados que indicam a obtenção de resultados benéficos);
- resultados benéficos (objetivos organizacionais alcançados por meio de TI).

Essas relações são mostradas na Figura 3.

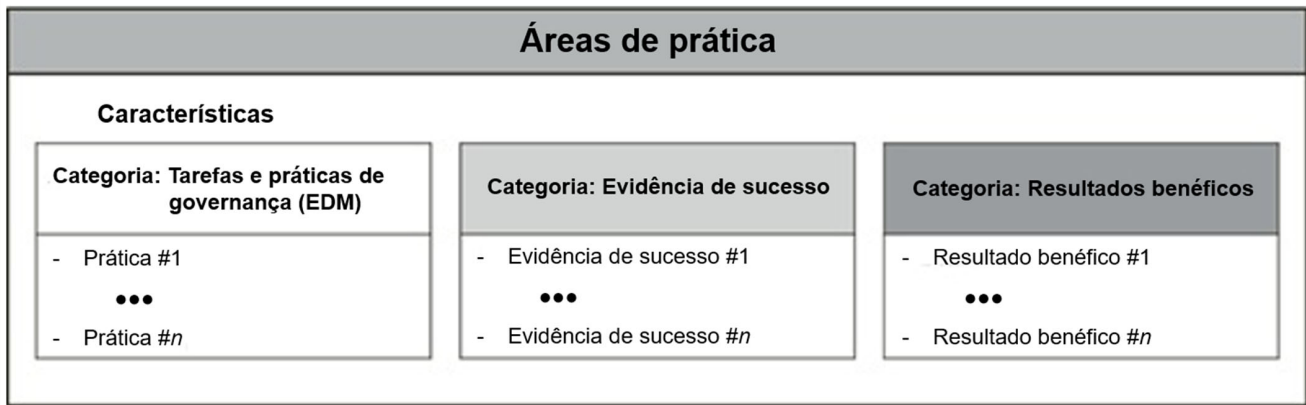


Figura 3 – Áreas de prática, suas três categorias e características distintas para governança de TI

As características de exemplo, por área de prática e categoria, são fornecidas nas Tabelas A.1 a A.7 do Anexo A como parte da estrutura de avaliação da amostra para a governança de TI.

Prevê-se que as organizações personalizem as características para se adequar às suas circunstâncias organizacionais específicas.

6.2.3 Modelo de medição para a governança de TI

A ISO/IEC TS 38501 define um modelo de medição que é mais qualitativo do que quantitativo por natureza, uma vez que os padrões baseados em princípios se concentram na obtenção de resultados, e não nos meios de alcançar resultados.

O modelo de medição da ISO/IEC TS 38501 foi adotado, com pequenas alterações, para incluir as tarefas e práticas de avaliação, direção e monitoramento (EDM). Mantém-se a escala de notação padronizada (coluna da esquerda), sendo definidas medidas específicas para cada uma das três categorias da governança de TI. Isso é mostrado na Tabela 9.

Tabela 9 – Escala de avaliação de medição

Classificação	Tarefas e práticas de EDM	Evidência de sucesso	Resultados benéficos
Desconhecido	Tarefas e práticas de EDM não sendo executadas	Nenhuma evidência de sucesso	Desconhecimento do nível de obtenção de resultados
Não aplicado	Desempenho limitado de tarefas e práticas de EDM	Pouca evidência de sucesso	A maioria dos resultados benéficos não está sendo alcançada
Parcialmente aplicado	Alguns avaliam e direcionam tarefas e práticas que estão sendo executadas, mas práticas de monitoramento limitadas	Alguma evidência de sucesso visível com um ou mais aspectos que não estão em vigor	Alguns resultados benéficos sendo alcançados até certo ponto, com um ou mais resultados benéficos não sendo alcançados
Amplamente aplicado	A maioria das tarefas e práticas de avaliação e direção é executada com um grau razoável de práticas de monitoramento	Todas as evidências de sucesso visíveis em grande medida, com certos aspectos totalmente em vigor	Todos os resultados benéficos sendo alcançados em grande medida, com certos resultados benéficos sendo totalmente alcançados
Totalmente aplicado	Todas as tarefas e práticas de EDM sendo totalmente executadas	Todas as evidências de sucesso totalmente implementadas e funcionando de forma eficaz	Todos os resultados benéficos sendo totalmente alcançados

6.2.4 Estrutura de avaliação para a governança de TI

A estrutura de avaliação para a governança de TI é então definida aplicando-se o modelo de medição a cada categoria da governança de TI para cada área de atuação. Isso é ilustrado na Figura 4.

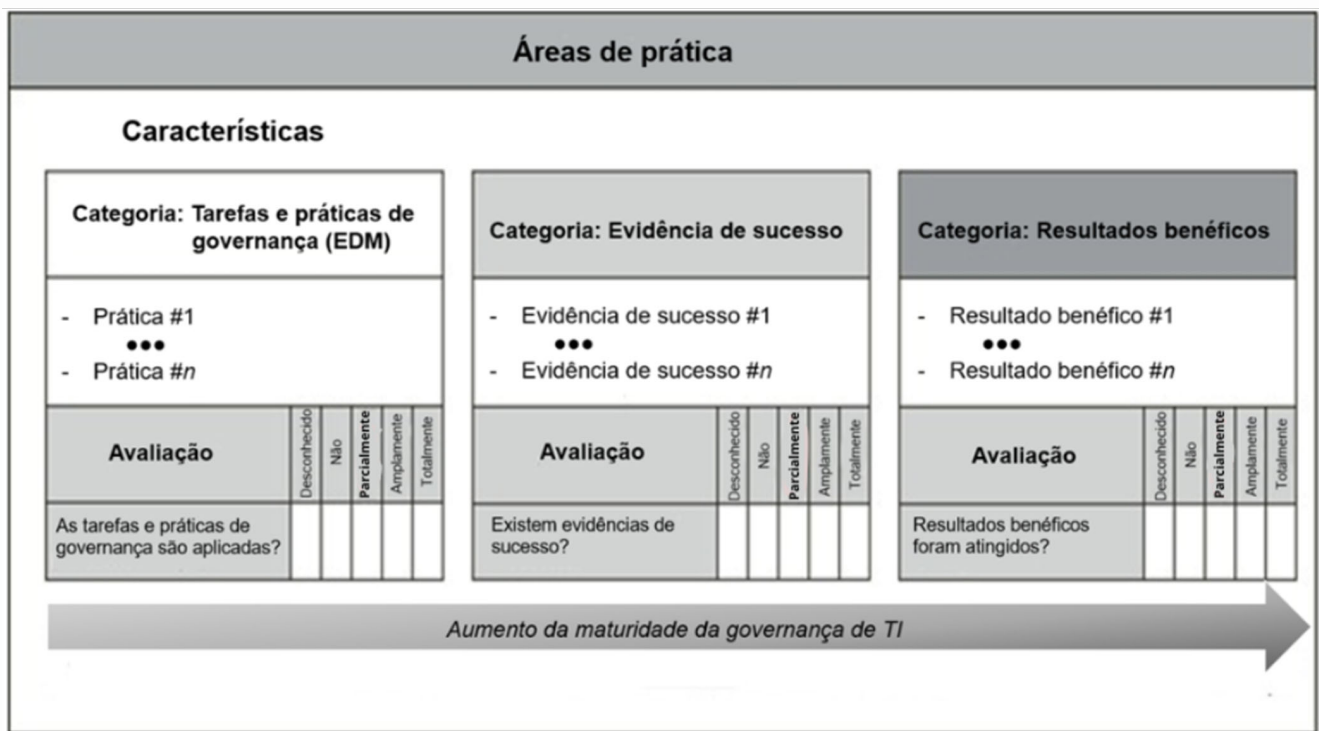


Figura 4 – Estrutura de avaliação para a governança de TI

O modelo de medição é aplicado à categoria geral da governança de TI, e não às características individuais dentro de cada categoria, pelos seguintes motivos:

- avaliar características individuais dentro de uma categoria cria complexidade adicional, exigindo uma fórmula de agregação por categoria;
- características diferentes podem ser percebidas como mais importantes do que outras, necessitando de um esquema de ponderação que acrescentaria mais complexidade;
- a avaliação ao nível da governança de TI não trará maior precisão à abordagem de avaliação inerentemente qualitativa e exigirá trabalho adicional. Isso pode levar à percepção de “exagero”.

A Figura 4 também ilustra a relação entre as categorias da governança de TI e o aumento da maturidade da governança de TI, conforme indicado pela seta na parte inferior do diagrama. Isso pode ser resumido da seguinte forma:

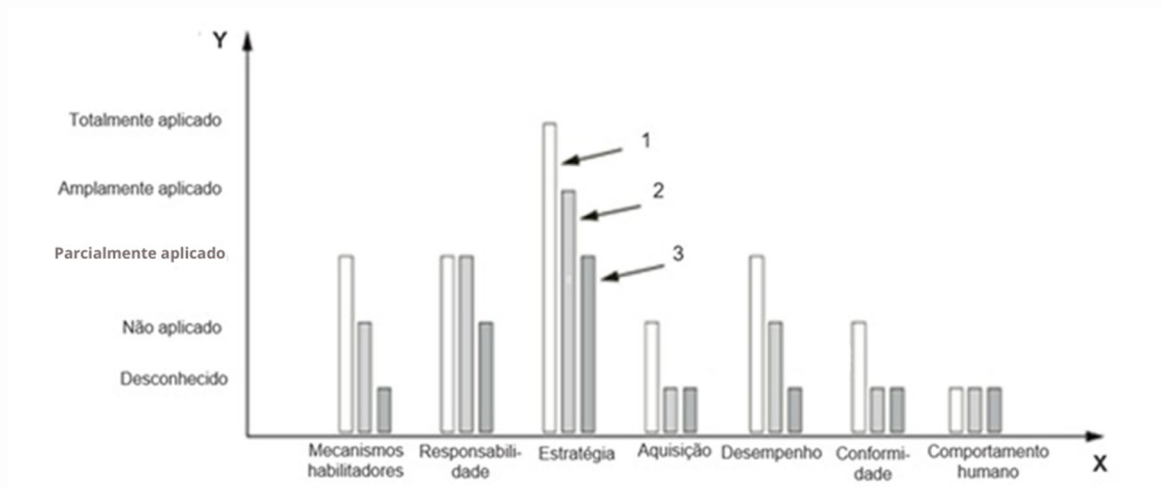
- na ausência da governança de TI formalizada, é provável que a organização tenha um baixo nível de maturidade em governança de TI;
- para melhorar o nível de maturidade, o órgão de governança pode assumir uma governança adequada das tarefas e práticas de TI;
- isso pode levar a uma melhor implantação e uso da TI na organização, conforme demonstrado pela evidência de sucesso;
- isso, por sua vez, pode apoiar e permitir a obtenção de resultados benéficos para a organização.

Esses conceitos são expandidos ainda mais no modelo de maturidade da governança de TI (ver 6.4).

6.3 Avaliação da governança de TI

A avaliação da governança de TI é realizada por meio da classificação de cada categoria, para todas as áreas de prática no escopo do modelo de referência da governança de TI.

A Figura 5 mostra um exemplo de representação gráfica de uma avaliação para todas as áreas de prática da governança de TI. Isso precisaria ser apoiado com detalhes apropriados em um relatório, conforme abordado em 7.3.



Legenda

- | | | | |
|---|--|---|------------------|
| 1 | Tarefas e práticas de governança (EDM) | X | Áreas de prática |
| 2 | Evidência de sucesso | Y | Classificação |
| 3 | Resultados benéficos | | |

Figura 5 – Exemplo de representação gráfica para uma avaliação da governança de TI

6.4 Modelo de maturidade para governança de TI

O modelo de maturidade para governança de TI está relacionado à crescente capacidade de uma organização de obter níveis com características-chave mais altas de capacidade em sua governança de TI.

O tema abrangente evolui desde a execução inicial de tarefas de governança, passando pela visualização de evidências de sucesso e, eventualmente, até a obtenção de resultados benéficos para a organização. Essa capacidade crescente precisa ser demonstrada em todas as áreas da governança de TI.

O nível de maturidade para governança de TI da organização é baseado na classificação das características de cada categoria, para todas as áreas de prática no modelo de referência da governança de TI, e é obtido de acordo com o modelo de medição descrito em 6.2.3.

Cada nível de maturidade descreve a classificação mínima para todas as áreas de prática que a organização precisa alcançar em cada categoria da governança de TI. Por exemplo, para alcançar uma classificação de nível 2, em todas as áreas de prática, as tarefas de governança (EDM) precisam ser “amplamente aplicadas”, enquanto as evidências de sucesso e resultados benéficos precisam ser “um pouco aplicadas”.

O nível de maturidade da governança de TI deve ser determinado conforme a Tabela 10.

Tabela 10 – Modelo de maturidade para a governança de TI (continua)

Características				
Tarefas de governança (EDM)	Evidência de sucesso	Resultados benéficos		
Desconhecido ou não aplicado	Desconhecido ou não aplicado	Desconhecido ou não aplicado	— Nenhum compromisso da liderança com a governança de TI — Órgão de governança e diretoria executiva não conhece os mecanismos que podem ser aplicados para governar a TI — Falta de controles internos para TI — A organização desconhece amplamente os riscos associados ao uso da TI	Sem governança (Nível 0)
Um pouco aplicado	Desconhecido ou não aplicado	Desconhecido ou não aplicado	— Órgão de governança e diretoria executiva tem ciência do propósito e dos objetivos da governança de TI — Implementação básica de mecanismos da governança de TI iniciaram — Alguns controles internos de TI estão implantados — A organização está ciente dos riscos associados ao uso da TI	Governança inicial (Nível 1)
Amplamente aplicado	Um pouco aplicado	Um pouco aplicado	— Órgão de governança e diretoria executiva começam a demonstrar compromisso com a governança de TI — Principais partes interessadas identificadas e engajadas — Implementação de mecanismos da governança de TI mais ampla em toda a organização — Implementação de controles internos para TI mais ampla em toda a organização — Organização começando a gerenciar os riscos de TI — Benefícios que começam a ser alcançados a partir de investimentos em TI	Governança aplicada (Nível 2)

Tabela 10 (continuação)

Características				
Tarefas de governança (EDM)	Evidência de sucesso	Resultados benéficos		
Totalmente aplicado	Amplamente aplicado	Um pouco aplicado	— Ambiente propício para a governança de TI, estabelecido pelo órgão de governança, incluindo compromisso de liderança, conscientização, educação e engajamento das partes interessadas — Estrutura da governança de TI estabelecida, incluindo políticas, estruturas e processos — Sistema de controle interno para TI como parte dos sistemas de gestão da organização estabelecido — A organização identifica oportunidades para melhorar a governança de TI — A organização garante que os riscos de TI sejam gerenciados — Os benefícios são regularmente alcançados com investimentos em TI	Governança estabelecida (Nível 3)

Tabela 10 (continuação)

Características				
Tarefas de governança (EDM)	Evidência de sucesso	Resultados benéficos		
Totalmente aplicado	Totalmente aplicado	Amplamente aplicado	— Ambiente sustentado e propício à governança de TI, resultando em mudanças comportamentais no órgão de governança e diretoria executiva — Estrutura da governança de TI aprimorada, incluindo estatuto, papéis e responsabilidades, grupo diretor de governança e reserva de poderes ao órgão de governança — Sistema para controle interno de TI aprimorado para apoiar a governança de TI, incluindo Responsabilidade, Estratégia, Aquisição, Desempenho, Conformidade e Comportamento Humano — Análise crítica contínua implementada para assegurar a melhoria da governança de TI na organização — A organização assegura que os riscos de TI sejam gerenciados e que os investimentos em TI impulsionem a obtenção de valor ao negócio	Governança alcançada (Nível 4)

Tabela 10 (conclusão)

Características				
Tarefas de governança (EDM)	Evidência de sucesso	Resultados benéficos		
Totalmente aplicado	Totalmente aplicado	Totalmente aplicado	— Ambiente propício para governança de TI otimizado, resultando em mudanças culturais e comportamentais por toda a organização — Estrutura da governança de TI otimizada, para atender aos requisitos organizacionais e externos — Sistema de controle interno otimizado para TI, atendendo aos requisitos organizacionais e externos — A organização aproveita consistentemente as oportunidades de melhoria de TI a partir da análise crítica contínua e do <i>feedback</i> obtido de todas as partes interessadas — Análise crítica contínua otimizada com ciclos de <i>feedback</i> a todas as partes interessadas, assegurando a melhoria da governança de TI na organização — A organização assegura que os riscos de TI sejam gerenciados e que a inovação de TI impulse a transformação dos negócios	Governança otimizada (Nível 5)

7 Atividades de avaliação

7.1 Planejamento da avaliação

Um plano para a avaliação deve ser desenvolvido e documentado pelo avaliador, que deve ser analisado criticamente e aprovado pelo patrocinador. O plano deve incluir no mínimo:

- o patrocinador e o relacionamento do patrocinador com a organização (ver 5.1 e 5.3.3);
- os objetivos da avaliação (ver 5.1 e 5.2);
- o escopo da avaliação (ver 5.1);
- o tipo de avaliação (ver 5.2);
- as áreas de atuação e os grupos característicos para avaliação (ver 6.2.1 e 6.2.3);

- o calendário da avaliação (ver 5.2);
- as atividades a serem realizadas durante a avaliação (ver 5.2 e 7.2);
- os papéis e responsabilidades dos participantes na avaliação (ver 5.3);
- os recursos necessários para realizar a avaliação (ver 5.3);
- o orçamento da avaliação (ver 5.2);
- a descrição do relatório de avaliação previsto (ver 7.3).

O Anexo A fornece uma estrutura de avaliação de amostra, ajudando as organizações a realizar a avaliação da governança de TI. Cada organização deve personalizar as áreas de prática por meio da revisão, adição e remoção de características em cada categoria, conforme apropriado, com base na extensão em que a organização determinou seu estado futuro de governança.

Os papéis e responsabilidades da avaliação devem ser atribuídos e comunicados ao pessoal afetado pela avaliação.

7.2 Realização da avaliação

7.2.1 Coleta dos dados

Os dados requeridos para avaliar a governança de TI devem ser suficientes para cobrir o escopo da avaliação, conforme detalhado no plano de avaliação.

Os dados determinados acima devem ser coletados de forma sistemática, incluindo os seguintes requisitos:

- devem ser identificadas e coletadas evidências objetivas que sirvam de base para a verificação das classificações;
- devem ser desenvolvidos métodos para a coleta de evidências subjetivas, incluindo a lista de perguntas ao órgão de governança, diretoria executiva e profissionais de TI dentro da organização;
- as evidências objetivas e subjetivas devem ser avaliadas, assegurando que sejam suficientes para satisfazer o propósito, o escopo e o tipo de avaliação.

7.2.2 Condução da avaliação

O processo de avaliação pode variar, dependendo das áreas de atuação da governança de TI e das características que estão sendo avaliadas, conforme descrito no plano de avaliação. No entanto, devem ser seguidas as atividades comuns abaixo:

- classificar as características na área de prática da governança de TI de acordo com o modelo de medição (ver 6.2.3);
- registrar a relação entre a área de prática da governança e as características que estão sendo classificadas e os dados coletados (ver 7.2.1);
- determinar o nível de maturidade (ver 6.4);

- examinar os níveis de maturidade avaliados e determinar a causa-raiz da maturidade mais baixa como base para melhoria (ver 6.4);
- identificar e documentar a lista de melhorias (ver 7.3).

7.3 Notificar a avaliação

O avaliador deve elaborar um relatório formal que reúna as principais conclusões da avaliação. Além disso, caso seja necessário, uma documentação de apoio relevante deve ser compilada e disponibilizada. O relatório deve também incluir um plano de melhoria que aborde quaisquer deficiências ou riscos importantes que tenham sido identificados. O relatório formal deve ser documentado e enviado ao patrocinador da avaliação, de forma a permitir uma comunicação eficaz ao patrocinador e às partes afetadas, devendo ser aprovado pelo órgão de governança.

Os principais aspectos no conteúdo do relatório devem incluir:

- data e duração da avaliação;
- nomes e papéis dos avaliadores;
- participantes da avaliação (por nome, papel ou área funcional);
- escopo da avaliação;
- tipo de avaliação adotada;
- modelo de maturidade e classificação;
- resultado da avaliação para a governança de TI na organização;
- indicadores de melhoria e mitigação de riscos.

Anexo A (informativo)

Estrutura de avaliação – Áreas de prática para a governança de TI

Este Anexo fornece um exemplo de estrutura de avaliação para as sete áreas de prática do modelo de referência da governança de TI. Ele contém exemplos e características de governança de TI, por categoria das ABNT NBR ISO/IEC 38500, ISO/IEC TS 38501 e ISO/IEC TR 38502, e é fornecido apenas para fins informativos.

Os avaliadores devem se envolver com o órgão de governança e com a Alta Direção para entender as características específicas da governança de TI organizacional e, então, personalizar o conteúdo deste Anexo para adequá-lo às suas circunstâncias específicas da organização.

As características podem ser de natureza qualitativa ou quantitativa, mas convém que tenham como objetivo ser específicas, pertinentes, realisticamente alcançáveis e mensuráveis.

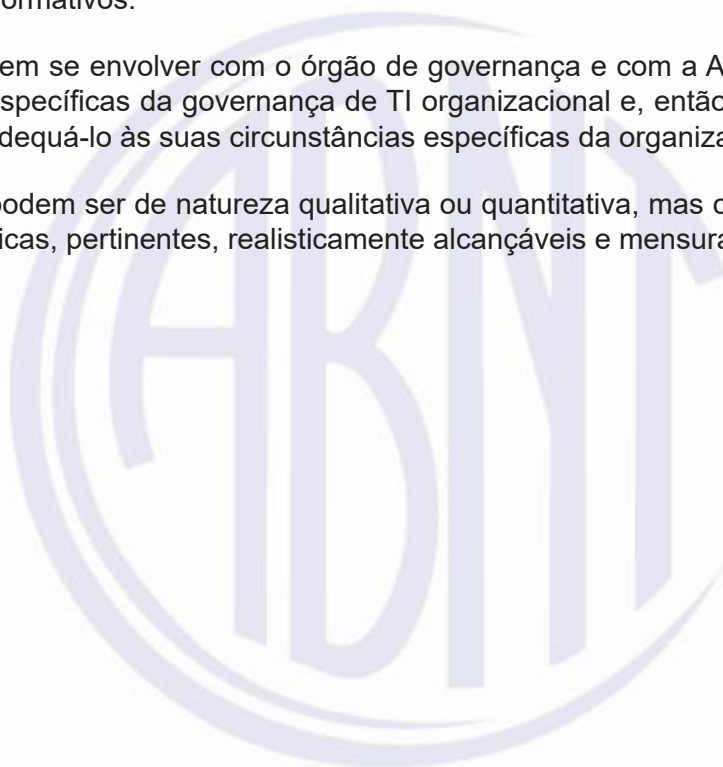


Tabela A.1 – Mecanismos de habilitação (continua)

Tarefas e práticas de governança (EDM)	Evidência de sucesso	Resultados benéficos
— Os órgãos de governança monitoram se os mecanismos apropriados para governança de TI estão estabelecidos. — Os órgãos de governança avaliam regularmente a conformidade interna da organização com sua estrutura de governança de TI.	— Uma estrutura de governança é estabelecida, incluindo: — estratégias, políticas, estruturas de tomada de decisão, termos de referência, estatuto etc. — É criado um grupo diretor de governança, incluindo: — administração e documentação, gestão do programa de mudanças etc. — O órgão de governança considera relevantes os requisitos internos e externos na tomada de decisões importantes de TI, incluindo: — estratégia e objetivos de negócios, apetite ao risco, cultura organizacional etc.; — ambiente regulatório, avanços tecnológicos, tendências geracionais etc. — Um patrocinador de negócios é nomeado para liderar a governança de TI. — As partes interessadas são gerenciadas adequadamente, incluindo: — partes interessadas identificadas; partes interessadas conscientes do propósito, de seus papéis e responsabilidades; — atividades de melhoria contínua são realizadas, incluindo monitoramento; compreensão do órgão de governança sobre o valor da TI; apreciação da direção sobre a necessidade da TI para apoiar e viabilizar os negócios etc.	— A governança de TI aborda aspectos relevantes e é administrada de forma eficaz. — Há uma liderança efetiva na governança de TI. — As partes interessadas estão totalmente engajadas e contribuem efetivamente para a governança de TI na organização. — Há melhoria contínua na governança de TI.

Tabela A.1 (conclusão)

Avaliação	Desconhecido	Não	Parcialmente	Amplamente	Totalmente	Avaliação	Desconhecido	Não	Parcialmente	Amplamente	Totalmente	Avaliação	Desconhecido	Não	Parcialmente	Amplamente	Totalmente
As tarefas e práticas de governança estão sendo aplicadas?						Há evidências de sucesso?						Os resultados benéficos estão sendo alcançados?					

Tabela A.2 – Responsabilidade (continua)

Tarefas e práticas de governança (EDM)	Evidência de sucesso	Resultados benéficos
— O órgão de governança orienta que os planos sejam executados de acordo com as responsabilidades de TI atribuídas. — Os órgãos de governança monitoram o desempenho daqueles que recebem responsabilidade na governança de TI (por exemplo, as pessoas que atuam em comitês de direção ou apresentam propostas ao órgão de governança). — O órgão de governança monitora o uso de TI para garantir que estejam sendo alcançados os benefícios pretendidos. — O órgão de governança avalia as opções de atribuição de responsabilidades em relação ao uso atual e futuro da TI pela organização. — O órgão de governança avalia a competência daqueles que têm a responsabilidade de tomar decisões sobre TI. — O órgão de governança determina que os acordos de fornecimento (incluindo acordos de fornecimento internos e externos) apoiem as necessidades de negócios da organização.	— Os diretores executivos lideram os processos de negócios, a estrutura organizacional e o desenvolvimento humano ao implementar soluções de TI. — Os diretores executivos tratam a TI como um retorno dos investimentos, não apenas como um custo a ser reduzido. — Os diretores executivos determinam o melhor modelo de entrega de TI, considerando: — estruturas de direitos de decisão e controle (centralizadas, descentralizadas, federadas etc.); — fornecimento: otimização da provisão de TI (estratégia de fornecimento); — Relatórios de indicadores-chave de desempenho ao órgão de governança, relacionados às responsabilidades pelo fornecimento e uso de TI.	— A organização implementa com sucesso mudanças de negócio viabilizadas pela TI. — O valor organizacional é gerado pela TI. — A organização recebe a qualidade dos serviços de que necessita da maneira mais eficaz e eficiente possível.

Tabela A.2 (conclusão)

Avaliação	Desconhecido	Não	Parcialmente	Amplamente	Totalmente	Avaliação	Desconhecido	Não	Parcialmente	Amplamente	Totalmente	Avaliação	Desconhecido	Não	Parcialmente	Amplamente	Totalmente
As tarefas e práticas de governança estão sendo aplicadas?						Há evidências de sucesso?						Os resultados benéficos estão sendo alcançados?					

Tabela A.3 – Estratégia (continua)

Tarefas e práticas de governança (EDM)	Evidência de sucesso	Resultados benéficos
— Ao considerar planos e políticas, o órgão de governança avalia o uso de TI e de atividades de TI para assegurar que estejam alinhados com os objetivos da organização e que satisfaçam os principais requisitos legítimos das partes interessadas. — O órgão de governança avalia as opções para garantir decisões eficazes e em tempo hábil sobre o uso de TI em apoio aos objetivos de negócios. — O órgão de governança direciona a preparação e o uso de estratégias e políticas que garantam que a organização se beneficie dos desenvolvimentos em TI. — O órgão de governança monitora até que ponto a TI oferece suporte ao negócio.	— Estratégias e planos de TI aprovados que estão alinhados à estratégia e aos objetivos da organização, atendendo aos requisitos de recursos e prazos. — Políticas de TI aprovadas em alinhamento com os objetivos estratégicos da organização. — Os requisitos de negócio relativos à usabilidade, confidencialidade, integridade e disponibilidade dos dados usados para decisões são identificados e atendidos. — A TI costumava: — habilitar, interromper e redefinir modelos de negócios; — interagir e conectar-se com os clientes. — Relatórios de indicadores-chave de desempenho ao órgão de governança, relacionados à implementação de estratégias e aos planos de TI.	— As operações da organização são efetivamente apoiadas pela TI e a mudança estratégica é adequadamente habilitada pela TI. — Os sistemas de apoio à tomada de decisão da organização fornecem informações em tempo hábil e de alta qualidade. — Os objetivos da organização são viabilizados pela inovação de TI.

Tabela A.3 (conclusão)

Avaliação	Desconhecido	Não	Parcialmente	Amplamente	Totalmente	Avaliação	Desconhecido	Não	Parcialmente	Amplamente	Totalmente	Avaliação	Desconhecido	Não	Parcialmente	Amplamente	Totalmente
As tarefas e práticas de governança estão sendo aplicadas?						Há evidências de sucesso?						Os resultados benéficos estão sendo alcançados?					

Tabela A.4 – Aquisição

Tarefas e práticas de governança	Evidência de sucesso	Resultados benéficos
— O órgão de governança avalia as opções, disponibilizando-as à TI para execução das propostas aprovadas, equilibrando os riscos e o valor para o custo dos investimentos propostos. — O órgão de governança monitora até que ponto os recursos e orçamentos alocados são priorizados de acordo com os objetivos de negócio. — O órgão de governança determina que os ativos de TI (sistemas e infraestrutura) sejam adquiridos de maneira adequada, incluindo a preparação de documentação adequada, garantindo, ao mesmo tempo, que os recursos necessários sejam fornecidos. — O órgão de governança monitora até que ponto sua organização e fornecedores mantêm o entendimento compartilhado da intenção da organização ao fazer qualquer aquisição de TI. — O órgão de governança garante a alocação de recursos suficientes para que a TI atenda às necessidades da organização, de acordo com as prioridades acordadas e as restrições orçamentárias. — O órgão de governança monitora o progresso das propostas de TI aprovadas para garantir que elas estejam atingindo os objetivos nos prazos exigidos usando os recursos alocados. — O órgão de governança monitora os investimentos em TI para garantir que eles forneçam os recursos necessários.	— Investimentos em TI estruturados em portfólios, retornos aceitáveis sobre os investimentos necessários para atender minimamente aos índices de desempenho. — O processo de aquisição de TI garante que as soluções atendam: <i>business case</i>, risco, funcionalidade, usabilidade, arquitetura, segurança, desempenho, disponibilidade etc. — Programas de mudança estruturados para fornecer capacidades de negócio com gestão cuidadosa de custos, riscos, cronograma, desenvolvimento humano e benefícios. — Relatórios de indicadores-chave de desempenho ao órgão de governança, relacionados às aquisições de TI.	— Investimentos em TI são priorizados na medida em que sua contribuição potencial para o negócio é atraente e alcançável. — Os requisitos de negócios são totalmente suportados por soluções de TI selecionadas. — Os programas de implementação prosseguem de acordo com o planejado e alcançam benefícios ao negócio.

Tabela A.4 (conclusão)

Avaliação	Desconhecido	Não	Parcialmente	Amplamente	Totalmente	Avaliação	Desconhecido	Não	Parcialmente	Amplamente	Totalmente	Avaliação	Desconhecido	Não	Parcialmente	Amplamente	Totalmente
As tarefas e práticas de governança estão sendo aplicadas?						Há evidências de sucesso?						Os resultados benéficos estão sendo alcançados?					

Tabela A.5 – Desempenho

Tarefas e práticas de governança (EDM)						Evidência de sucesso						Resultados benéficos					
— O órgão de governança avalia os planos propostos pelos gerentes para garantir que a TI dará suporte aos processos de negócio com a capacidade e o desempenho necessários. — O órgão de governança avalia as propostas para abordar a operação normal contínua da organização e o tratamento dos riscos associados ao uso de TI. — O órgão de governança avalia os riscos à operação contínua do negócio, decorrentes das atividades de TI. — O órgão de governança avalia os riscos à integridade das informações e à proteção dos ativos de TI, incluindo a propriedade intelectual associada e a memória organizacional.						— TI adequadamente responsiva e disponível, mesmo em caso de alta demanda e/ou desastre. — Mudanças e atualizações de TI devidamente planejadas, avaliadas e implementadas somente com a interrupção planejada do negócio. — Políticas, procedimentos e tecnologias eficazes em vigor para garantir que a TI esteja protegida contra acesso não autorizado ou alterações nos dados. Controles em vigor para garantir a integridade dos dados. — Central de atendimento eficaz que resolve requisições, incidentes e problemas, assegurando que os clientes sejam atendidos dentro dos níveis de serviço definidos. — Estratégias e processos eficazes de segurança de TI e gestão de riscos em vigor. — Relatórios de indicadores de desempenho ao órgão de governança, relacionados aos níveis de serviço de TI, qualidade, custos e riscos.						— Todas as partes interessadas capazes de interagir e realizar transações com sistemas de TI que fornecem os serviços, níveis de serviço e qualidade de serviço para atender às suas necessidades. — As informações são completas, precisas, seguras e acessíveis, e estão protegidas contra perda ou uso indevido. — As partes interessadas foram efetivamente auxiliadas ao requerer suporte de TI.					
Avaliação	Desconhecido	Não	Parcialmente	Amplamente	Totalmente	Avaliação	Desconhecido	Não	Parcialmente	Amplamente	Totalmente	Avaliação	Desconhecido	Não	Parcialmente	Amplamente	Totalmente
As tarefas e práticas de governança estão sendo aplicadas?						Há evidências de sucesso?						Os resultados benéficos estão sendo alcançados?					

Tabela A.6 – Conformidade (continua)

Tarefas e práticas de governança	Evidência de sucesso	Resultados benéficos
— O órgão de governança orienta que as políticas sejam estabelecidas e aplicadas para permitir que a organização cumpra as obrigações internas no uso de TI. — O órgão de governança monitora até que ponto as políticas são devidamente seguidas. — O órgão de governança monitora as atividades de TI, por exemplo, descarte de ativos e dados, para garantir que as obrigações relevantes sejam cumpridas. — O órgão de governança assegura que o uso de TI esteja sujeito a uma gestão de riscos adequada. — O órgão de governança avalia regularmente até que ponto a TI atende às obrigações (regulatórias, legislativas, contratuais), políticas internas, normas e diretrizes profissionais. — O órgão de governança orienta os responsáveis por estabelecer mecanismos regulares para garantir que o uso da TI esteja em conformidade com as obrigações, políticas internas, normas e diretrizes pertinentes. — O órgão de governança orienta que todas as ações relacionadas à TI sejam éticas. — O órgão de governança monitora o cumprimento e a conformidade de TI por meio de relatórios apropriados e práticas de auditoria, garantindo que as revisões sejam oportunas, abrangentes e adequadas para a organização.	— Políticas relevantes em vigor que são regularmente analisadas criticamente, para assegurar a conduta organizacional adequada em relação ao fornecimento e uso de TI. — Sistemas de rastreamento em vigor para garantir que educação e treinamentos apropriados sejam fornecidos a todos os funcionários sobre políticas e procedimentos organizacionais. — Sistemas, processos e controles de gestão de TI maduros, garantindo a conformidade com as políticas organizacionais, requisitos de serviço e apetite aos riscos. — Testes regulares dos principais sistemas e controles de gerenciamento de riscos, incluindo planos de continuidade de negócios e recuperação de desastres. — Acompanhamento contínuo da legislação pertinente, implementação de políticas, processos e controles de TI necessários, bem como o fornecimento de garantia independente. — Relatórios de indicadores-chave de desempenho ao órgão de governança, relacionados à conformidade com os principais controles organizacionais.	— A organização cumpre suas políticas, regras e mandatos que são implementados adequadamente pela TI. — A organização gerencia adequadamente suas informações e transações para que não haja violações de requisitos legais e/ou regulatórios.

Tabela A.6 (conclusão)

Avaliação	Desconhecido	Não	Parcialmente	Amplamente	Totalmente	Avaliação	Desconhecido	Não	Parcialmente	Amplamente	Totalmente	Avaliação	Desconhecido	Não	Parcialmente	Amplamente	Totalmente
As tarefas e práticas de governança estão sendo aplicadas?						Há evidências de sucesso?						Os resultados benéficos estão sendo alcançados?					

Tabela A.7 – Comportamento humano

Tarefas e práticas de governança EDM)	Evidência de sucesso	Resultados benéficos
— O órgão de governança avalia as atividades de TI para garantir que os comportamentos humanos sejam identificados e adequadamente considerados. — O órgão de governança orienta que as atividades de TI sejam consistentes com o comportamento humano identificado. — O órgão de governança orienta que os funcionários de TI sigam as diretrizes relevantes para o comportamento e desenvolvimento profissional. — O órgão de governança monitora as atividades de TI para assegurar que os comportamentos humanos identificados permaneçam relevantes e que a atenção adequada seja dada a eles. — O órgão de governança orienta que riscos, oportunidades, problemas e preocupações podem ser identificados e relatados por qualquer pessoa, a qualquer momento. — O órgão de governança monitora as práticas de trabalho para garantir que sejam consistentes com o uso apropriado da TI.	— A diretoria executiva fornece liderança, apoiada por política educacional apropriada, treinamento e monitoramento de conformidade para usuários e provedores de serviços. — Educação contínua, treinamento e testes de competência para todos os usuários, em todos os aspectos do uso da TI da organização. — Riscos de TI relacionados ao comportamento humano identificados, rastreados e gerenciados adequadamente. — Relatórios de indicadores-chave de desempenho ao órgão de governança, relacionados ao comportamento humano.	— As partes interessadas usam a TI da organização de maneira aceitável. — Eficiência nos negócios e valor gerado pelos funcionários que usam a TI de maneira produtiva e eficaz.

Tabela A.7 (conclusão)

Avaliação	Desconhecido	Não	Parcialmente	Amplamente	Totalmente	Avaliação	Desconhecido	Não	Parcialmente	Amplamente	Totalmente	Avaliação	Desconhecido	Não	Parcialmente	Amplamente	Totalmente
As tarefas e práticas de governança estão sendo aplicadas?						Há evidências de sucesso?						Os resultados benéficos estão sendo alcançados?					